

****Critique of the Gymnasium's Use of Examination Monitoring Software****

Date: 19-04-2024

Decision

Public Authorities

Critique

Supervision / Own Initiative Case

Legal Basis for Processing

Obligation to Inform

Data Protection by Design and Default

The Danish Data Protection Agency has concluded a supervision regarding Roskilde Cathedral School's use of software for examination monitoring. The Agency criticizes that Roskilde Cathedral School has not conducted a sufficient risk assessment and, as a result, has not ensured data protection by design.

Journal Number: 2023-421-0019.

****Summary****

The Danish Data Protection Agency initiated a case on its own initiative against Roskilde Cathedral School on February 27, 2023, after becoming aware through media coverage that several gymnasiums intended to use software to monitor students' examination performance to prevent and control cheating.

In this context, the Agency decided to supervise several gymnasiums' processing of personal data in connection with their use of examination monitoring software. The focus of the case was on the gymnasiums' compliance with the rules regarding legal basis for processing, the principle of proportionality, storage limitation, obligation to inform, as well as data protection by design and by default.

Based on the responses received, the Agency selected certain gymnasiums for further investigation, including Roskilde Cathedral School. The Agency has now made a decision in the case regarding Roskilde Cathedral School's use of examination monitoring software.

****Roskilde Cathedral School Generally Complies with Data Protection Rules****

The Danish Data Protection Agency found that Roskilde Cathedral School has generally complied with the rules regarding legal basis for processing, the principle of proportionality, storage limitation, and obligation to inform, and that Roskilde Cathedral School's processing of personal data has thus been in accordance with the General Data Protection Regulation (GDPR) Article 6(1), Article 5(1)(c) and (e), and Articles 12, 13, and 14.

****Roskilde Cathedral School Encouraged to Reconsider Obligation to Inform Notification****

However, the Agency encourages Roskilde Cathedral School to consider whether – and if so, to what extent – it is possible to make the obligation to inform notification provided to students even more understandable and to use clearer and simpler language. At the same time, the Agency urges the gymnasium to ensure that the references are correct and that only relevant information is included.

****The Danish Data Protection Agency Recommends a Renewed Risk Assessment****

The Agency also found grounds to criticize that Roskilde Cathedral School has not conducted a sufficient risk assessment and, as a result, has not implemented appropriate technical or organizational measures designed to ensure that no additional information is collected beyond what is intended. Roskilde Cathedral School's processing of personal data has therefore not been in accordance with the rules on data protection by design in GDPR Article 25(1).

In light of this, the Agency recommends that Roskilde Cathedral School, as part of its potential future use of examination monitoring, conduct a renewed risk assessment in accordance with Article 25 of the Regulation, which addresses the risks mentioned in the decision, and also takes into account to a much greater extent that examination performance – and monitoring – occurs using the student's own computer. The gymnasium must also make students more aware of the identified risks, encourage

students to take, and provide concrete examples of, measures that students can take to avoid unintentionally exposing (private) information in the examination situation. This may include advisory information that students can use a different browser during the exam that does not contain their private information.

The Danish Data Protection Agency has subsequently concluded its supervision of three other gymnasiums' use of examination monitoring software with reference to this decision and recommended that the relevant gymnasiums familiarize themselves with the decision and assess whether – and if so, to what extent – the gymnasiums need to make adjustments to their potential use of examination monitoring software to ensure compliance with data protection rules.

The Danish Data Protection Agency hereby returns to the case, where the Agency initiated a case on its own initiative against Roskilde Cathedral School on February 27, 2023. The supervision was initiated after the Agency became aware through media coverage that several gymnasiums intended to use software to monitor students' examination performance to prevent and control cheating.

In this context, the Agency decided to supervise Roskilde Cathedral School's use of software to monitor students' examination performance. This specifically concerns the gymnasium's compliance with the rules regarding (i) legal basis for processing, (ii) the principle of proportionality, (iii) storage limitation, (iv) obligation to inform, and (v) data protection by design and by default.

1. **Decision**

After reviewing the case, the Danish Data Protection Agency finds that Roskilde Cathedral School's processing of personal data has been processed in accordance with the General Data Protection Regulation's Article 6, paragraph 1, Article 5, paragraph 1, letters c and e, as well as Articles 12, 13, and 14. However, the Data Protection Agency finds that there is grounds to express criticism that Roskilde Cathedral School's processing of personal data has not been carried out in accordance with the rules in the General Data Protection Regulation's[1] Article 25, paragraph 1. Below follows a detailed review of the case and a justification for the Data Protection Agency's decision.

2. Case Presentation

The Data Protection Agency became aware through media coverage[2] that a number of high schools intended to use software to monitor students' exam performance in order to prevent and control cheating. The Data Protection Agency has previously assessed and made decisions regarding the use of software-based exam monitoring in 2019[3], 2020[4], and 2021[5]. On this basis, the Data Protection Agency decided to supervise a number of high schools' use of software to monitor students' exam performance. The supervision was initially conducted through a written questionnaire survey, so that the Data Protection Agency could make an overall assessment of whether the high schools had made the necessary evaluations and considerations required under data protection regulations. Based on the received responses, the Data Protection Agency assessed which high schools it wished to conduct a more in-depth review of, including asking additional questions and requesting documentation. Roskilde Cathedral School was selected for a closer examination of the school's use of the exam monitoring software ExamCookie.

2.1 Comments from Roskilde Cathedral School

Roskilde Cathedral School has generally stated that the school did not use ExamCookie at the time the supervision was initiated, but that the school expected to use the program in connection with the holding of exams in the summer of 2023. Roskilde Cathedral School subsequently confirmed to the Data Protection Agency that the school used ExamCookie in the summer of 2023. In this context, Roskilde Cathedral School has stated that the school is the data controller for the processing of personal data that occurs in connection with the monitoring of students' computers during exams, and that the company ExamCookie is the school's data processor regarding the processing of personal data that occurs through the use of the exam monitoring software. ExamCookie is a program designed to monitor students' computer activity during an exam to ensure that the exam is conducted according to the guidelines. The program is downloaded onto students' computers before the exam starts.

Roskilde Cathedral School has stated that the program can register activity on the computer. The school's exam supervisor thus gets a complete overview of the activity that takes place on students' computers during the exam. After the exam, the program indicates which students have used prohibited aids such as chatbots, communication with the outside world, translation programs, and file sharing. This constitutes documentation to clarify whether the student has cheated. Similarly, it also ensures that students suspected of cheating can document and refute this. Roskilde Cathedral School has stated that the use of ExamCookie involves the processing of personal data in the form of registration data and exam data. Registration data includes:

- Student's full name
- Student's class and possibly group
- Student's school and year
- Student's exam schedule
- Student's Unilogin user ID and password
- Student's CPR number

Exam data includes the information collected from the student's computer during the exam and generally includes:

- Relevant screenshots
- Content of copied text and images in the clipboard
- Programs in the foreground on the computer
- Active URLs in browsers

Roskilde Cathedral School has stated that screenshots are collected when there is a new program in the foreground, when there is a screen change of 5% (pixel change), and at random time intervals of 30-120 seconds. Roskilde Cathedral School has assessed that the processing of screenshots is relevant and necessary to register whether unauthorized functions have been used in otherwise permitted programs, e.g., verb conjugation in Word or translation of text during a language exam. Regarding the information in students' clipboards, Roskilde Cathedral School has stated that the processing of this type of information serves as a tool that can help reveal whether the student has used illegal material or illegal aids such as ChatGPT in their assignment. It is further stated that measures have been established when collecting information from the computer's clipboard to limit the collection to only relevant information, as students are instructed to clear their clipboards of historical content prior to the exam. Processing information about programs in the foreground allows, according to Roskilde Cathedral School, for monitoring the programs that the student specifically accesses during the exam. It is assessed as relevant and necessary to see whether the student has used programs that are not permitted during the exam. As for the collection of active URLs in browsers, Roskilde Cathedral School has stated that...

The processing is necessary to reveal whether there has been a connection to web addresses or servers that are not permitted during the exam. It is also possible to collect information about the computer's active processes through the program. Roskilde Katedralskole has assessed that this information goes beyond what is relevant and necessary for the purpose, which is why the school – referring to the principle of data minimization – has opted out of this function and therefore does not process this information. The same applies to information about active network activity collected via the computer's network card. According to Roskilde Katedralskole's documentation, the school has assessed that it is also not necessary and has therefore asked the provider to remove this functionality from the program. This, according to the documentation, occurred in the summer of 2022.

Roskilde Katedralskole has stated that the school processes personal data with the aim of detecting and preventing cheating during exams and thereby ensuring that the exam or test can be conducted under uniform conditions for all students, including ensuring:

1. that the answer is prepared without improper assistance
2. that only permitted aids are used
3. that the examinee has not submitted another's work as their own, and
4. that the examinee has not used their previously assessed work without reference to it.

Registration data is processed with the purpose of uniquely identifying the student, including the student's institution, class, group, exam date, and start and end times. Exam data is processed to ensure that the exam has been conducted according to applicable rules.

Roskilde Katedralskole has stated that the school assesses the need for exam monitoring for each individual exam. In this context, the school evaluates whether it is possible to achieve the desired purpose with less intrusive methods, for example, by using exam proctors. In cases where Roskilde Katedralskole decides to use exam monitoring, the school has assessed that the exam proctors do not have the ability to effectively monitor students' activities on their computers.

Roskilde Katedralskole has further noted that the plagiarism check used cannot reveal the use of unauthorized functions or programs, including whether the student has wholly or partially used ChatGPT or similar technology during the exam. The plagiarism check also cannot reveal whether students have had someone else write the answer.

The school has stated that the processing is carried out based on Article 6, paragraph 1, letter e of the General Data Protection Regulation. In this context, the school has referred to a number of regulations issued under, among others, Consolidation Act No. 1076 of September 4, 2013, on education for the student exam (the Gymnasium Act) as the supplementary national legal basis for processing the personal data in question.

This concerns Sections 14-15 and 20 of the regulation on exams and assessments in general and preparatory youth and adult education. Among other things, the following is stated:

“§ 14. The institution must ensure that exams are conducted under conditions suitable to exclude that the examinee communicates inadvertently.

[...]

15. During exams, the use of aids, including electronic ones, is permitted, subject to paragraph 2, unless restrictions are specified in the rules for the individual education.

Paragraph 2. The examinee has access to the internet during exams that are subject to supervision, only concerning their own learning materials, their own notes, and their own work [...]

20. The answer must be the examinee's own and independent answer, unless otherwise stated in the rules for the individual education. An examinee who during an exam obtains or provides another examinee with improper assistance in answering a task or uses unauthorized aids shall be expelled from the institution for the relevant exam.

Paragraph 2. If there arises a suspicion during or after an exam that an examinee has improperly obtained or provided assistance, as referred to in paragraph 1, has submitted another's work as their own, or has used their previously assessed work without reference to it, this shall be reported to the institution. If the suspicion is confirmed, and the action has had or could have an impact on the assessment, the institution shall expel the examinee from the relevant exam. When a written assignment is prepared by a group of examinees, without the individual contributions being identifiable, and the assignment is included in the basis for assessment in a subsequent oral examination, the examinees have a joint responsibility for the answer, and all examinees in the group can be expelled from the exam upon confirmed suspicion of improper assistance.

[...]

Furthermore, the school has referred to Sections 5-7 of the regulation on certain rules regarding exams and assessments in the gymnasium education, where the following is stated:

“§ 5. The institution organizes the conduct of exams so that they can be conducted under conditions suitable to exclude that the examinee communicates inadvertently, uses unauthorized aids, or otherwise violates the exam rules.

Paragraph 2. The institution may establish more detailed rules.

for the conduct of examinations (local examination regulations).

§ 3. The local examination regulations may include, among other things, rules regarding supervision, execution, attendance, access to the internet according to § 6, subsections 4-5, use of cloud services, monitoring and logging of network activity, monitoring of the candidates' computers/tablets, etc., and the use of electronic devices in general.

§ 4. The institution informs the candidates about the examination rules in a manner that, in relation to local conditions, best contributes to the candidates being aware of the importance of complying with the rules.

6. During the examination, it is permitted for the candidate to use aids, including digital ones, unless restrictions have been set for the individual examination.

§ 2. However, it is not permitted for the candidate to bring equipment to the examination, including mobile phones and similar devices, with which the candidate can communicate or which can establish access to the internet. In an examination where the candidate must prepare and submit the answer digitally, the device or devices with which the candidate prepares and submits the answer are exempted.

§ 3. Access to the internet during examinations is not permitted for the candidate, subject to subsections 4 and 5, unless access has been granted for the individual examination.

§ 4. The candidate may use the internet during an examination where access to the internet is not permitted according to subsection 3, insofar as it concerns digital access to teaching materials that have been used in teaching at the institution and are listed in the teaching description, provided that they cannot be brought and stored locally.

§ 5. Own notes and own work must be brought and stored locally during the examination. However, the candidate has access to access the material via the internet during the examination in cases where the material has such a nature that it cannot be stored locally.

§ 6. The rules in subsections 2-5 do not apply to an examination where the candidate is not required to be present at the institution or another location designated by the institution for the conduct of the examination.

7. The answer must be the candidate's own and independent answer. If all or part of the examination is conducted as a group examination, the answer, to the extent that this follows from the rules for the examination, must be the group's own and independent answer.

§ 2. The institution dismisses the candidate from the examination or assigns the candidate the grade -3 (minus three) if the candidate engages in actions to obtain or provide another candidate with improper assistance in answering a task in connection with an examination. The same applies if the candidate uses unauthorized aids, presents others' work as their own, or submits their own previously assessed work without reference to it. [...]

The gymnasium has finally referred to § 1 of the executive order on the access to bring and use equipment, including digital aids, during examinations in the upper secondary education[8], which has the following wording:

"§ 1. During an examination in the upper secondary education, it is permitted for the candidate to use aids, including digital ones, unless restrictions have been set for the individual examination.

§ 2. However, it is not permitted for the candidate to bring equipment to the examination, including mobile phones and similar devices, with which the candidate can communicate or which can establish access to the internet. In a written examination, where the candidate must prepare and submit the answer digitally, the device or devices with which the candidate prepares and submits the answer are exempted. In an oral examination, the computer or tablet that the candidate uses to access aids, which the candidate must have digital access to, is also exempted.

§ 3. The rules in subsection 2 do not apply to an examination where the candidate is not required to be present at the institution or another location designated by the institution for the conduct of the examination."

The gymnasium has also stated that there is no processing of special categories of data covered by Article 9 of the Data Protection Regulation, as ExamCookie does not, as a rule, have access to other than the information mentioned above. However, Roskilde Cathedral School emphasizes the risk that students themselves access special categories of information during the examination, and a screenshot of this is taken. Therefore, students are instructed prior to the examination that it is not permitted to access such information during the examination.

Personal data is generally stored for 30 days on ExamCookie's servers, as Roskilde Cathedral School has assessed that this is the shortest possible period for the gymnasium to review the collected information. In special cases, e.g., in the event of suspected cheating or in processing an examination

complaint, the information may be stored for up to three months. Roskilde Cathedral School may also request ExamCookie to delete information at any time.

Roskilde Cathedral School has prepared written information material for the students, which is distributed to the students prior to the examination. In this context, students are informed about: the purpose of the processing and the legal basis

where the information comes from

categories of personal data

who has access to the collected data

how long personal data is stored

the rights of the data subject

****Contact Information for the School as Data Controller****

****Contact Information for the Data Protection Authority as Supervisory Authority and Information on the Possibility to Lodge a Complaint with the Authority****

Students are further instructed on the use of ExamCookie. The gymnasium ensures that a written guide is provided, describing the processing activities performed by the program and the precautions that students should observe when using the program. Students are explicitly informed that it is not permitted to access sensitive information during the examination.

Roskilde Katedralskole has finally stated that the gymnasium has ensured that the software's functionality is designed to ensure data protection by design and by default. The gymnasium has assessed that the risk to the rights and freedoms of the data subjects in connection with the processing of personal data is low and acceptable, which is why the gymnasium has determined that there is no need to prepare a impact assessment.

****3. Justification for the Data Protection Authority's Decision****

****3.1 Legal Basis for Processing****

The Data Protection Authority establishes that Roskilde Katedralskole is the data controller for the processing of personal data that occurs in connection with the monitoring of students' computers during examinations. Likewise, the authority establishes that the processing of personal data is aimed at detecting and preventing exam cheating. Furthermore, the Data Protection Authority establishes that Roskilde Katedralskole processes information about the student's name, class, group, school, year, UNI-login, user ID, and personal identification number, as well as information in the form of activity logs on the student's computer during the exam. The Data Protection Authority thus establishes that Roskilde Katedralskole processes personal data covered by Article 6 of the General Data Protection Regulation and information about personal identification numbers covered by Section 11 of the Data Protection Act. Finally, the Data Protection Authority establishes that Roskilde Katedralskole does not, as a rule, process special categories of data covered by Article 9 of the General Data Protection Regulation as part of exam monitoring, and that the processing of such data must be considered incidental to the extent that it may occur.

It is the Data Protection Authority's assessment that Roskilde Katedralskole's processing of the relevant personal data is necessary for the gymnasium's performance of its public tasks, cf. Article 6, paragraph 1, letter e of the General Data Protection Regulation, and Section 14, paragraph 1 of Executive Order No. 343 of April 8, 2016, on examinations and tests in general preparatory youth and adult education, as well as Section 5, paragraphs 1 and 2 of Executive Order No. 1276 of November 27, 2017, on certain rules regarding examinations and tests in upper secondary education. The Data Protection Authority has particularly emphasized that the information is processed with the aim of detecting and preventing exam cheating, which falls within the public task that the gymnasium can and must perform. The Data Protection Authority further finds that Roskilde Katedralskole can process information about students' personal identification numbers under Section 11, paragraph 1 of the Data Protection Act, as these are processed for the purpose of unambiguous identification of the students.

****3.2 Principle of Proportionality****

Processing of personal data must – in addition to being based on a relevant legal basis – always be carried out in accordance with a number of fundamental principles. This includes, among other things, the principle of proportionality in Article 5, paragraph 1, letter c of the Regulation, which states that

personal data must always be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed. Thus, one must always assess how the pursued purpose can reasonably be fulfilled by processing the least possible amount of data, and if possible, entirely without personal data.

It is the Data Protection Authority's assessment that Roskilde Katedralskole's use of software-based exam monitoring can fundamentally occur within the framework of Article 5, paragraph 1, letter c of the General Data Protection Regulation. The Data Protection Authority has emphasized that the purpose of the software-based exam monitoring is to supervise during the exam and to detect and prevent exam cheating, and that taking an exam is a short and limited process, which – regardless of the software-based exam monitoring – generally must be considered a monitored situation.

Furthermore, the Data Protection Authority has emphasized that in light of the fact that certain digital aids are permitted during written exams, it is difficult – and in some situations impossible – to ensure against illegal use of otherwise permitted aids. This may be the case, for example, where permitted aids such as word processing programs contain prohibited functions such as automatic verb conjugation or similar. Likewise, the authority has emphasized that technological developments in the form of generative artificial intelligence mean that existing plagiarism checks, whereby an exam answer can be compared with text content from the internet or previous answers, are no longer effective. Finally, the Data Protection Authority has emphasized that access to the internet is not generally prohibited during exams, and that a general blocking of internet traffic is not appropriate, just as it is not possible in advance to determine which (permitted) internet addresses may be relevant for the examinee to access during the exam, and that Roskilde Katedralskole assesses the need for software-based exam monitoring for each exam, including whether it is possible to use less intrusive methods.

The question is then to what extent all the collected types of information are sufficient, relevant, and limited to what is necessary to fulfill the purpose. Roskilde Katedralskole has assessed that the collection and processing of information in the form of screenshots, active URLs, active programs, as well as the content of the clipboard is necessary to fulfill the purpose of detecting and preventing exam cheating. In this regard, the school has further explained the extent to which the individual types of information are necessary to process in order to detect and prevent exam cheating.

Roskilde Katedralskole has also assessed that the collection of information about the computer's active processes goes beyond what is relevant and necessary to detect and prevent exam cheating, which is why the school has opted out of this function and therefore does not process this information. Similarly, the school has assessed that information about active network connections from the computer's network card is not necessary and therefore is not processed. The Data Protection Agency finds that there is no basis to override Roskilde Katedralskole's assessment that the processing of all the types of information in question is necessary in relation to the purpose of detecting and preventing cheating, cf. Article 5, paragraph 1, letter c of the General Data Protection Regulation.

The Data Protection Agency has particularly emphasized that the collection of the types of information in question is especially necessary to detect and prevent exam cheating in various ways, which can take different forms, e.g., the use of illegal functions in existing programs, communication with fellow students, or the use of chatbots. The Data Protection Agency also notes that the agency assumes that the collection of information about the computer's active processes and network traffic are functions that are effectively turned off by Roskilde Katedralskole, and that the information is therefore never collected as part of exam monitoring, and that it is not merely a matter of the school disregarding the information as part of a possible review of data for potential exam cheating.

3.3 Storage Limitation

The Data Protection Agency has noted that Roskilde Katedralskole has set a storage period of 30 days, after which the information is deleted. Roskilde Katedralskole has stated that the 30-day period is the shortest possible duration within which the school can review the collected information. In special cases, e.g., in the event of suspicion of cheating or in the case of a complaint, the information may be stored for three months. The Data Protection Agency finds that Roskilde Katedralskole's

storage of the information is in accordance with Article 5, paragraph 1, letter e of the General Data Protection Regulation. The Data Protection Agency has emphasized that the school has made an assessment of how long it is relevant to store the information in question in light of the purpose of the processing, and that there do not appear to be circumstances that provide grounds for overriding the established storage period.

3.4 Obligation to Inform

Roskilde Katedralskole has stated that the school has prepared written information material for the students, which is provided to the students prior to the exam, in order to fulfill the school's obligation to inform under the General Data Protection Regulation. The school has sent a copy of this material to the Data Protection Agency. The Data Protection Agency finds – after reviewing the submitted material – that, overall, Roskilde Katedralskole's observance of the school's obligation to inform is in accordance with Articles 12, 13, and 14 of the General Data Protection Regulation. The Data Protection Agency has particularly emphasized that the information that must be provided under Articles 13 and 14 of the Regulation is included in the material that is given to the students regarding how their information is processed as part of exam monitoring, and that this material is provided to the students before the individual exam takes place.

Furthermore, the Data Protection Agency has emphasized that the information obligation notice is addressed to older students aged 16-20 years, and that the necessary information is described relatively clearly. However, the Data Protection Agency encourages Roskilde Katedralskole to consider whether – and if so, to what extent – it is possible to make the information obligation notice given to the students even more understandable and to use clearer and simpler language. At the same time, the Data Protection Agency encourages the school to ensure that the references are correct and that only relevant information is included. The Data Protection Agency refers in this context to the European Data Protection Board's guidelines on transparency, which state, among other things: "The requirement that the information be 'easily understandable' means that it should be comprehensible to an average member of the intended target group. Understandability is closely linked to the requirement to use clear and simple language. Responsible data controllers will be familiar with the individuals from whom they collect information and can use this knowledge to determine what the target group is likely to understand. For example, a data controller collecting personal data about professionals may assume that the target group has a higher degree of understanding than a data controller collecting personal data about children. If data controllers are uncertain about the degree of understandability and transparency of the information and the effectiveness of user interfaces/messages/policies, etc., they can test these, e.g., through mechanisms such as user panels, readability checks, formal and informal contacts, and...

dialog with, among others, business groups, consumer interest organizations, and supervisory authorities, where relevant. [...] The requirement for clear and simple language means that information must be provided in the simplest way possible, avoiding complex sentence and language structures. The information should be concrete and definitive, and it should not be formulated in abstract or ambiguous terms or allow for different interpretations. In particular, the purpose of and legal basis for the processing of personal data should be clear. [...] Linguistic indicators of meaning such as "can," "could," "some," "often," and "possible" should also be avoided. If data controllers choose to use vague language, they should, in accordance with the accountability principle, be able to demonstrate why the use of such language cannot be avoided and how it does not undermine fair processing. Sections and sentences should be well-structured using bullet points and indentations to signal hierarchical relationships. The formulation should be active rather than passive, and excessive use of nouns should be avoided. The information that data subjects receive should not contain overly legalistic, technical, or specialized language and terminology. [...] When data controllers address children [16] and know or should know that their goods/services are particularly used by children [...], they should ensure that the vocabulary, tone, and style of the language used are appropriate for children and understood by children, so that the children to whom the information is directed understand that the message/information is intended for them [18]. [...] The Article 29 Working Party is of the opinion that transparency is an independent right that applies to both children and adults. [...] Therefore, data

controllers – in accordance with the specific mention of transparency measures directed at children in Article 12(1) (supported by Recitals 38 and 58) – when addressing children or being aware that their goods and services are particularly used by children of an age where they can read, are obliged to ensure that any information or message is communicated in clear and simple language or through a manner that children can easily understand. [...] [16] The term "child" is not defined in the General Data Protection Regulation, but the Article 29 Working Party recognizes, in accordance with the UN Convention on the Rights of the Child, which all EU member states have ratified, that a child is a person under 18 years of age. [18] It is stated in Recital 38 that "Children should be afforded specific protection of their personal data, as they are often less aware of the risks, consequences, and safeguards involved and their rights regarding the processing of personal data." In Recital 58, it is noted that "Since children should be afforded specific protection, all information and communications addressed to a child should be in clear and simple language, so that the child can easily understand it."

3.5 Data Protection by Design

It follows from Article 25(1) of the Data Protection Regulation that the data controller – both at the time of determining the means of processing and at the time of the actual processing – must take appropriate technical and organizational measures designed for the effective implementation of data protection principles and for integrating the necessary safeguards into the processing to meet the requirements of this regulation and protect the rights of data subjects. This must be done taking into account the current technical level, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons that the processing entails. Given the provision's risk-based approach, the data controller must therefore conduct a risk assessment and, in this context, identify any risks to the rights of data subjects, and determine their likelihood and severity in order to implement measures to effectively mitigate the identified risks. Identification of the specific risks associated with the processing activity in question is thus a prerequisite for compliance with Article 25(1) of the Data Protection Regulation, as the assessment of what constitutes appropriate technical and organizational measures is based on the specifically identified risk profile. Roskilde Cathedral School has stated that the gymnasium has assessed that the risk to the rights and freedoms of data subjects in connection with the processing of personal data as part of exam monitoring is low and acceptable, and that the program's functionality is designed to ensure data protection by design and through default settings. The Data Protection Authority acknowledges that Roskilde Cathedral School has identified certain risks to students' rights and freedoms. This includes, among other things, the risk that the gymnasium inadvertently collects information that is already present in the student's clipboard when the exam begins, as well as the risk that the student accesses information about themselves or others that the gymnasium does not have a purpose for processing. This could, for example, be the student's health information. Specifically, Roskilde Cathedral School has stated the following: "ExamCookie does not, as a rule, have access to other than the above-mentioned general and confidential personal data. This is provided that a student does not access this data themselves during the exam, and that a screenshot is not taken of it. Roskilde Cathedral School has assessed that there is no legal basis for processing sensitive personal data in connection with

****Exam Monitoring.**** Students are therefore instructed well in advance of the examination, both orally and in writing, about what such personal data includes, what processing activities take place during the examination, and the school strongly emphasizes the necessity for students to follow the precautions indicated by the school to ensure that students do not inadvertently expose sensitive information during the examination. [...]

Roskilde Cathedral School has thus assessed that there is no risk of processing sensitive information, as the risk of processing or disclosing sensitive information on this basis is only considered to be hypothetical.

However, it is the Data Protection Authority's assessment that Roskilde Cathedral School has not identified and evaluated all the specific risks to students' rights and freedoms associated with the use

of exam monitoring, and that certain risks identified by the school have not been adequately addressed.

These include, for example, the following risks:

When processing screenshots, all information displayed on students' screens is collected. This means, for example, that when using a browser, information may appear in the form of students' private bookmarks, favorites, and similar items, as well as suggestions for various websites based on students' search and browsing history and favorites in the address bar. In these cases, Roskilde Cathedral School will inadvertently collect information through screenshots that the school has neither a purpose for processing nor a legal basis for processing.

Certain students may be entitled to take the exam under special examination conditions due to, for example, dyslexia. This may include permission to use special IT aids (e.g., text-to-speech, word suggestions, dictation, or text enlargement). In such cases, Roskilde Cathedral School will process information covered by Article 9 of the General Data Protection Regulation as part of the exam monitoring without having identified a relevant exception to the general prohibition on processing such information.

There may be files, folders, etc., on the student's computer, the name or metadata of which contains private information about the student. In these cases, Roskilde Cathedral School will inadvertently collect information through screenshots that the school has neither a purpose for processing nor a legal basis for processing.

Misconfiguration of the exam monitoring, for example, with incorrect specification of the exam start time, can – for students who install the exam monitoring well in advance of the exam start – lead to the collection of information about the student's private use of their computer before the exam starts.

It is thus the Data Protection Authority's opinion that the risk of inadvertent collection of personal data, including special categories of personal data, is not hypothetical.

It is then the Data Protection Authority's assessment that the inadequate risk assessment has contributed to Roskilde Cathedral School not having taken appropriate technical and organizational measures to ensure data protection by design and by default, cf. Article 25, paragraph 1 of the General Data Protection Regulation.

In this regard, the Data Protection Authority has emphasized that the configuration or setup of the program does not ensure that only information that the school has anticipated in connection with the decision to implement the software is collected and processed, and only in the manner that the school has anticipated. On the contrary, there is a predominant risk that inadvertent processing of information occurs, which Roskilde Cathedral School has no purpose for processing or legal basis for processing.

Finally, the Data Protection Authority has emphasized that Roskilde Cathedral School has not sufficiently taken into account in its risk assessment that the exam – and therefore the exam monitoring – takes place on students' private computers, where students' private information may be present in various ways.

Based on the above, the Data Protection Authority finds that Roskilde Cathedral School has not conducted a sufficient risk assessment, which is a prerequisite for being able to manage any risks to the rights of the data subjects and to implement measures to effectively mitigate the identified risks. As a result, Roskilde Cathedral School has not implemented appropriate technical or organizational measures designed to ensure that no additional information is collected beyond what is intended.

The Data Protection Authority therefore finds that Article 25 of the General Data Protection Regulation has not been complied with, which the Authority believes warrants criticism.

The Data Protection Authority recommends that Roskilde Cathedral School, as part of its potential future use of exam monitoring, conducts a renewed risk assessment in accordance with Article 25 of the Regulation, which addresses the aforementioned risks and, furthermore, takes much greater account of the fact that the exam – and monitoring – takes place using the student's own computer. At

the same time, the school should make students more aware of the identified risks, encourage students to take concrete steps to avoid inadvertently exposing (private) information in the examination situation. This may include, for example, guidance that students during the exam can use a different browser that does not contain their private information.

[1] Regulation (EU) of the European Parliament and of the Council 2016/679 of April 27, 2016 on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Berlingske.dk, New Times at Exams in High School: "Yes, it is surveillance", February 8, 2023: <https://www.berlingske.dk/metropol/nye-tider-ved-eksamen-i-gymnasiet-ja-det-er-overvaagning>
3 Data Protection Authority case no. 2018-432-0015: <https://www.datatilsynet.dk/afgoerelser/afgoerelser/2019/maj/fredericia-gymnasiums-behandling-af-personoplysninger-ved-brug-af-programmet-examcookie>

4 Data Protection Authority case no. 2019-432-0020: <https://www.datatilsynet.dk/afgoerelser/afgoerelser/2020/mar/den-digitale-proevevagt>

5 Data Protection Authority case no. 2020-432-0034: <https://www.datatilsynet.dk/afgoerelser/afgoerelser/2021/jan/universitets-brug-af-tilsynsprogram-ved-online-eksamen>

[6] Executive Order No. 343 of April 8, 2016 on examinations and tests in the general study preparatory youth and adult education.

[7] Executive Order No. 1276 of November 27, 2017 on certain rules regarding examinations and tests in the upper secondary education.

[8] Executive Order No. 224 of March 19, 2018 on the access to bring and use equipment, including digital aids, during examinations in the upper secondary education.

[9] See, among others, footnote 1, as well as the table in section 4.2, which contains a description of the types of personal data that Roskilde Cathedral School does not process, e.g., network cards and process lists.

[10] Article 29 Working Party Guidelines on Transparency under Regulation 2016/679, WP 260, adopted by the European Data Protection Board on May 25, 2018, p. 7ff.